

보도자료 (Press Release) · TLP:GREEN · 자유 인용 가능 (출처 표기 필수)

출처: Dennis Kim, 김호광, gameworker@gmail.com /

<https://github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT>

「Lazarus Group, 이번엔 가짜 채용 후 git hooks 한 줄로 개발자 워크스태이션 장악」

북한 사이버 작전, 한국 거래소·Web3·방산 협력사 직접 위협 — 누적 피해 67.5 억 달러

보고서 ID: CTI-2026-0510-LAZARUS-GITHOOKS-PRESS · 발행일: 2026-05-10

핵심 요지

OpenSourceMalware 가 2026 년 5 월 공개한 분석에 따르면, 북한 **Lazarus Group**(MITRE ATT&CK G1052)이 가짜 채용 캠페인의 2 단 악성코드 로더를 `.git/hooks/` 디렉터리에 은닉하는 새로운 기법을 도입했다.

이 디렉터리는 Git 이 자체적으로 추적하지 않는 사각지대로, **코드 리뷰·정적 분석·PR diff 어디에도 노출되지 않는다**. 표적 개발자가 단지 `git pull` 한 번을 실행하는 것만으로 코드 한 줄 직접 실행하지 않은 채 자격증명·암호화폐 지갑·SSH 키가 탈취된다.

이번 변종은 npm 패키지(2022~) → 가짜 화상회의 도구(2024) → 대규모 npm 캠페인 338 개(2025) → VS Code Tasks 악용(2026 Q1)에 이은 **5 번째 진화다**. 방어자가 한 통로를 막을 때마다 Lazarus 는 약 3~6 개월 안에 더 깊은 곳으로 집요하게 옮겨간다.

한 페이지로 보는 핵심 숫자

- 누적 가상자산 도난 (2017~2026 Q1): 67.5 억 달러+ (Chainalysis)
- 2025 년 단일 연도 도난: 20.2 억 달러 (역대 최대, 전년 대비 +51%)
- 2026 년 Q1 글로벌 가상자산 도난 중 라자루스 비중: 76% (단일 그룹 비대칭 위협)
- 단일 최대 사건: Bybit 2025 년 2 월, 15 억 달러 (인류 가상자산 역사상 최대 단일 도난)
- 자금 세탁 평균 소요: 도난 후 45 일 → USDT(Tron) → 중국·동남아 OTC 브로커 → 북한 통제 계좌
- 자금 회수율: 약 15% · 북한 GDP 중 비중: 약 13% (UN 모니터링 패널)
- 한국 직접 피해 대표 사례: 2019 년 11 월 Upbit 580 억 원 사고 (2024 년 한국 경찰의 공식 라자루스 귀속)

한국이 특히 위험한 이유

LinkedIn Korea 사용자 약 700 만 명에서 개발자 활동량이 글로벌 상위, **DAXA 5 대 원화 거래소(Upbit, Bithumb, Coinone, Korbit, Gopax)** 본사가 서울에 집중, 외화 결제 프리랜서 풀 증가, 국방·방산 협력사 개발자의 LinkedIn 노출 — 네 가지 구조적 요인이 중첩되어 한국 개발자는 글로벌 평균 대비 노출도가 현저히 높다.

모든 개발자가 오늘 실행할 한 줄

```
mkdir -p ~/.config/git/hooks && git config --global core.hooksPath ~/.config/git/hooks
```

이 명령어 한 줄로 클론한 저장소의 git hooks 가 실행되지 않는다. **비용 0 원, 시간 30 초.**

라자루스 가상자산 피해 연도별 추이 (2017 ~ 2026 Q1)

연도	DPRK 전체 추정 피해	주요 사건 (라자루스 귀속)
2017 ~ 2018	\$200M+	초기 거래소 침투 (Bithumb 등)
2019	\$200M+	Upbit 580 억 원 (한국, 2024 년 공식 귀속) · YouBit 파산 등
2020	\$300M+	KuCoin \$281M (일부 라자루스 추정)
2021	\$400M	다수 거래소 침해
2022	\$1.7B	Ronin/Axie Infinity \$625M (당시 역대 최대) · Harmony Horizon \$100M
2023	\$660M	Atomic Wallet \$100M · Stake.com \$41M · CoinEx \$27M · Alphapo · CoinsPaid
2024	\$1.34B (47 건)	Radiant Capital \$50M · IT 워커 위장 침투 12 건+ (DeFiance Capital 등)
2025	\$2.02B (역대 최대)	Bybit \$1.5B (역대 최대 단일 도난)
2026 Q1	\$577M (4 개월)	Drift Protocol \$285M · KelpDAO \$293M
누적 (2017 ~ 2026 Q1)	\$6.75B+	Chainalysis · Elliptic · UN 패널 교차 확인

자금 출처: UN 패널·미 재무부·FBI 공식 확인 — **북한 핵·미사일 프로그램의 1 차 자금원**. 라자루스의 가상자산 탈취가 북한 GDP 의 약 13%를 차지한다고 추정.

한국에 미치는 여파

1. 직접 피해 이력

시점	사건	피해 규모	비고
2017 ~ 2019	Bithumb 다수 침해	누계 1,400 억 원+	일부 라자루스 추정
2019-11	Upbit 580 억 원 사고	약 5,800 만 달러 (당시)	2024 년 한국 경찰 공식 라자루스 귀속 , 일부 자금 BTC-e 회수
2020 ~ 2024	다수 한국 Web3 프로젝트	미공개 다수	DAXA 회원사·소형 발행사 표적

2. 본 git hooks 캠페인의 한국 직접 노출 영역

영역	표적 자산	위협 시나리오
DAXA 5 대 거래소 백오피스 개발자 (Upbit, Bithumb, Coinone, Korbit, Gopax)	거래소 내부 시스템 자격증명, 핫월렛 운영 키	가짜 인터뷰 → 자격증명 유출 → 거래소 lateral movement
Web3 발행사 smart contract 개발자	Solidity deploy 키, 멀티시그 시드	deploy 키 유출 → 토큰 컨트랙트 owner 탈취 → 토큰 발행 권한 장악
국방·방산 협력사 개발자 (KAI, LIG 넥스원, 한화 등)	비공개 무기체계 코드	LinkedIn 노출 채용 정보 → 사회공학 → 군사 기밀 유출
AI 회사 ML 엔지니어	모델 가중치, 학습 데이터	채용 위장 → 워크스테이션 침투 → 지적재산권 유출
프리랜서 개발자 (Upwork, Fiverr, Toptal 한국 활동자)	다수 클라이언트 코드베이스	1 명 감염 → 다수 클라이언트로 백도어 잠복 확산

3. 권고 조치

개인 개발자:

1. 위 한 줄 명령어로 글로벌 git hook 경로 무력화
2. clone 직후 `ls -la .git/hooks/` 검사 습관화
3. npm 자동 스크립트 차단: `npm config set ignore-scripts true`
4. 외부에서 받은 코딩 과제는 격리 컨테이너에서만 실행: `docker run --rm --network none ubuntu:24.04 bash`
5. 하드웨어 키(YubiKey 등) 의무 사용, 암호화페 시드는 콜드월렛으로 영구 분리

조직 (거래소·Web3 발행사·방산 협력사):

1. **Deploy 키 환경 분리** — smart contract deploy 키·멀티시그 시드 보유
워크스테이션을 일반 개발 환경과 물리적·논리적으로 완전 분리 (HSM 또는 air-gap)
2. **EDR 룰 배포** — 본 보고서의 KQL(Microsoft Defender)·osquery 헌팅 룰을 사내 보안 도구에 즉시 적용
3. **MDM·도메인 정책** — 전사 Git 클라이언트의 `core.hooksPath` 를 회사 관리 디렉터리로 강제
4. **외부 프리랜서 코드 검역** — 격리 컨테이너에서 1 차 실행·검증을 PR 머지 전 의무 게이트로 신설
5. **신규 입사 OPSEC 교육** — Contagious Interview, SCARCRUFT, MCP 변종 통합 교육 모듈 의무화

자주 묻는 질문 (FAQ)

Q1. 라자루스(Lazarus Group)가 누구이고 왜 위험한가?

A1. 북한 정찰총국(RGB) 산하 국가지원 사이버 작전 부서. 2017 년 이후 누적 67.5 억 달러 이상의 가상자산을 탈취했으며, 이 수익은 **UN 패널·미국 재무부·FBI 가 공식 확인한 북한 핵·미사일 프로그램의 1 차 자금원**이다. UN 모니터링은 라자루스의

가상자산 탈취가 북한 GDP 의 약 13%를 차지한다고 추정한다. 2026 년 현재 글로벌 가상자산 도난의 76%를 단일 그룹이 차지하는 비대칭 위협이다.

Q2. 이번 git hooks 기법이 무엇이 새로운가?

A2. .git/hooks/ 디렉터리는 **Git 이 자체적으로 추적하지 않는 영역**이다. PR diff·git log·코드 리뷰·SAST(정적 분석)·표준 패키지 스캐너 어디에도 노출되지 않는다. 표적이 클론한 코드가 표면상 정상으로 보이는 이유다. 그런데 표적이 단지 git pull·git merge·git checkout 을 실행하는 순간 hooks 가 자동 발화되어 코드를 한 줄 직접 실행하지 않고도 **BeaverTail**(JavaScript 정보탈취) → **InvisibleFerret**(Python 백도어) 체인이 silent 설치된다.

Q3. 한국 개발자가 특히 위험한 이유?

A3. 네 가지 구조적 요인이 중첩된다.

1. **LinkedIn Korea 활성화** — 한국 사용자 약 700 만 명, 개발자·블록체인 분야 활동량이 글로벌 상위
2. **표적 가치 집중** — DAXA 5 대 원화 거래소 + 다수의 Web3 발행사 본사가 서울에 밀집
3. **외화 결제 프리랜서 풀** — Upwork·Fiverr·Toptal 에서 활동하는 한국 개발자 인구 증가, 가짜 리크루터 접근이 자연스럽다
4. **국방·방산 LinkedIn 노출** — 보안 등급 보유 협력사 개발자가 채용 정보를 공개 검색하는 패턴

Q4. 일반 개발자가 즉시 할 수 있는 조치는?

A4. 글로벌 git hook 경로를 무력화하는 한 줄을 즉시 실행한다.

```
mkdir -p ~/.config/git/hooks && git config --global core.hooksPath ~/.config/git/hooks
```

추가로 **(1)** clone 직후 ls -la .git/hooks/로 검사, **(2)** npm 자동 스크립트 차단(npm config set ignore-scripts true), **(3)** 외부에서 받은 코딩 과제는 docker run --rm -

-network none ubuntu:24.04 bash 같은 네트워크 차단 격리 환경에서만 실행, **(4)** 하드웨어 키(YubiKey 등) 의무 사용, **(5)** 암호화폐 시드는 워크스테이션에서 영구 분리(콜드월렛만 사용).

Q5. 거래소·Web3 발행사 차원의 조치는?

A5. 다섯 가지 우선순위 권고.

1. **Deploy 키 환경 분리** — smart contract deploy 키·멀티시그 시드 보유
워크스테이션을 일반 개발 환경과 물리적·논리적으로 완전 분리. HSM 또는 air-gap 머신 사용 의무화
2. **EDR 룰 배포** — 본 보고서의 KQL(Microsoft Defender)·osquery 헌팅 룰을 사내 보안 도구에 즉시 적용
3. **MDM·도메인 정책** — 전사 Git 클라이언트의 core.hooksPath 를 회사 관리 디렉터리로 강제
4. **외부 프리랜서 코드 검역** — 격리 컨테이너에서 1 차 실행·검증하는 단계를 PR 머지 전 의무 게이트로 신설
5. **신규 입사 OPSEC 교육** — Contagious Interview, SCARCRUFT, MCP 변종을 통합한 위협 인지 교육 모듈 의무화

Q6. 가짜 리크루터를 어떻게 식별하나? (업비트, 바이빗도 당한 사례)

A6. 5 분 검증 룰. **(1)** 회사 도메인 WHOIS 등록일 — 수주~수개월 이내 신규 등록이면 의심, **(2)** LinkedIn 직원 history — 회사 본인 계정 외 다른 직원 프로필이 거의 없거나 모두 신규면 의심, **(3)** 채용 공고가 회사 공식 사이트에 동일하게 게시되어 있는지 확인, **(4)** 영상 통화를 무리하게 회피하거나 음성만 고집하면 의심, **(5)** AI 생성 프로필 사진(눈동자 비대칭, 귀걸이 한쪽 누락 등) 의심. 한 가지라도 걸리면 코드 클론 전에 멈춘다.

Q7. 한국 정부·DAXA 의 대응 현황은?

A7. KISA(한국인터넷진흥원)와 NIS(국가정보원)는 라자루스 캠페인에 대한 정기 경보를 발령하고 있다. 2024 년 한국 경찰은 2019 년 Upbit 사고를 BTC-e 출금 패턴 분석으로 라자루스 귀속을 공식 발표한 바 있다. KoFIU(금융정보분석원)도 거래소 모니터링을

강화하고 있다. 다만 본 보고서는 (a) **DAXA 자율규제 가이드라인에 “개발자 워크스테이션 git hooks 검사” 의무 항목 추가**, (b) **KISA·NIS·KoFIU 공동 경보 발령**, (c) **국방·방산 협력사 LinkedIn 활동 가이드라인 신설**, (d) **LinkedIn 한국 지사 협력 가짜 리크루터 takedown 채널 강화**를 추가 권고한다.

Q8. 이번 변종을 막아도 다음 변종이 또 올까?

A8. 온다. 본 캠페인은 2022 년 이후 평균 12~18 개월마다 전달 메커니즘을 진화시켜 왔다. npm → 가짜 화상회의 도구 → 대규모 npm → VS Code Tasks → git hooks. 다음 표적은 .gitattributes filter, .npmrc 의 prepare 스크립트, .devcontainer/ 설정, Makefile 또는 IDE 확장(.vscode/extensions) 중 하나일 가능성이 높다. **단일 기법 차단이 아니라 “신뢰 비대칭(trust asymmetry) 자체를 측정·관리하는 거버넌스” 구축이 근본 해결책이다.**

인용 / 출처 표기 가이드

본 자료는 TLP:GREEN 으로 발행되며 **자유 인용** 가능합니다. 단, 모든 인용·재배포 시 **아래 출처를 반드시 명기해** 주십시오.

출처: Dennis Kim, 김호광, gameworker@gmail.com /
[https://github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-](https://github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT)
REPORT

추가 질문, 취재 요청, 기술 검증 협조 요청은 위 이메일로 문의 바랍니다.

Press Release · CTI-2026-0510-LAZARUS-GITHOOKS-PRESS · TLP:GREEN · 2026-05-10

© **2026 Dennis Kim (김호광)** · gameworker@gmail.com ·
<https://github.com/gameworkerkim/CYBER-THREAT-INTELLIGENCE-REPORT>